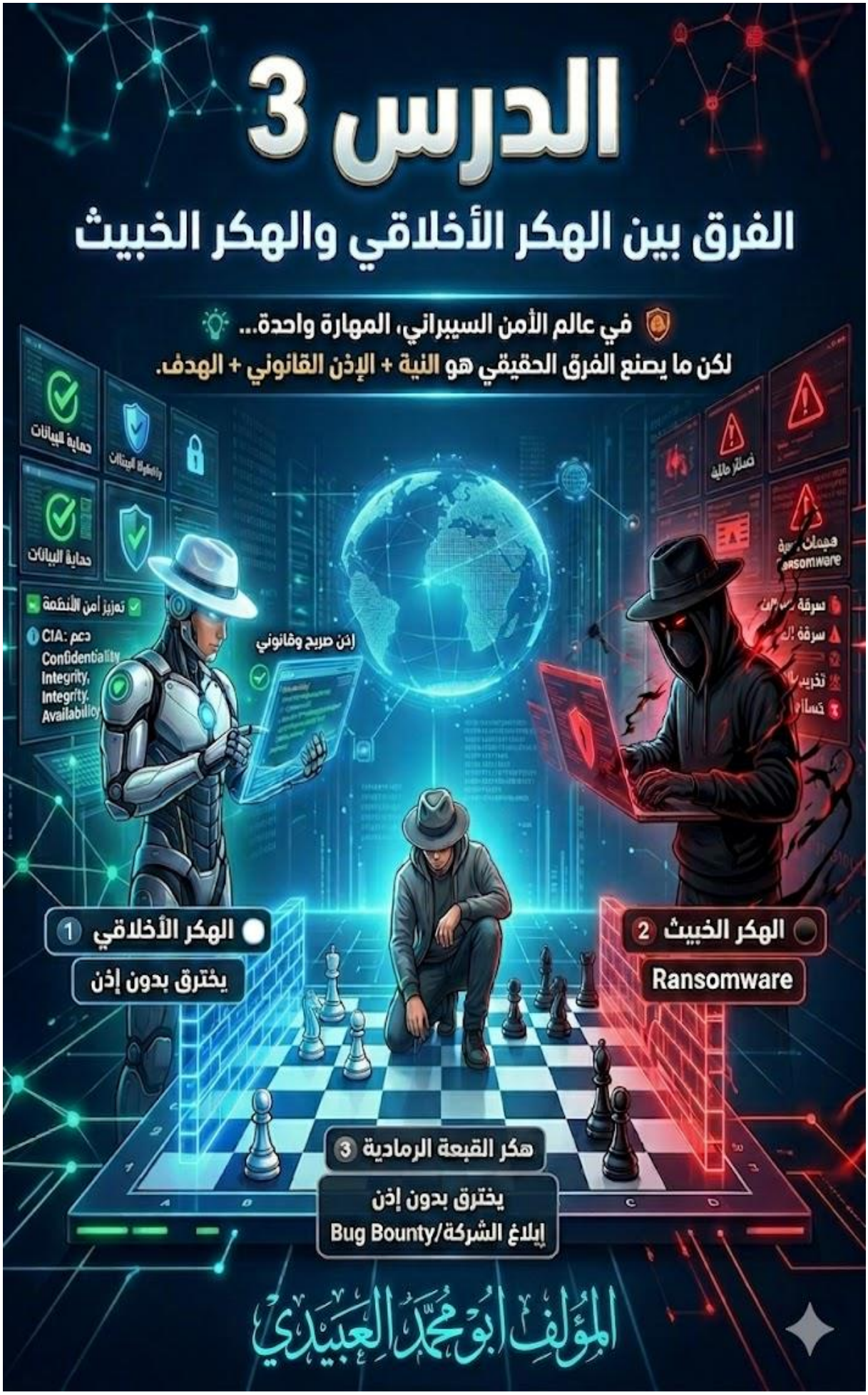
الدرس 3
الفرق بين الهكر الأخلاقي والهكر الخبيث
في عالم الأمن السيبراني، المهارة واحدة...
لكن ما يصنع الفرق الحقيقي هو النية + الإذن القانوني + الهدف.
حماية البيانات
حماية البيانات
تعزيز أمن الأنظمة
CIA: دعم
Confidentiality
Integrity,
Integrity,
Availability
إذن صريح وقانوني
الهكر الأخلاقي 1
يخترق بدون إذن
الهكر الخبيث 2
Ransomware
هكر القبعة الرمادية 3
يخترق بدون إذن
إبلاغ الشركة/Bug Bounty
المؤلف أبو محمد العبيدي

في عصر التحول الرقمي، أصبحت الأنظمة والشبكات والبيانات هدفًا رئيسيًا للهجمات الإلكترونية.
ورغم أن مهارات الاختراق واحدة في جوهرها، إلا أن طريقة الاستخدام، والنية، والإذن القانوني هي ما يحدد ما إذا كان الشخص عنصر حماية أو عنصر تهديد.

ولهذا السبب، قام خبراء الأمن السيبراني بتصنيف الهكرز إلى عدة فئات تُعرف باسم "القبعات"، ويُعد أشهرها:

- **الهكر الأخلاقي (White Hat)**
- **الهكر الخبيث (Black Hat)**
- **هكر القبعة الرمادية (Gray Hat)**

من هو الهكر الأخلاقي؟

الهكر الأخلاقي هو متخصص أمن سيبراني يمتلك نفس مهارات الاختراق المتقدمة،
لكن الفرق الجوهري أنه:

✅ **يعمل بإذن رسمي وقانوني**
✅ **هدفه الحماية وليس الإضرار**

غالبًا يكون موظف داخل شركة، أو متعاقد، أو مشارك في برامج **Bug Bounty**.

❖ **هو هدفه الحقيقي؟**

الهدف الأساسي للهكر الأخلاقي هو:

- اكتشاف **نقاط الضعف والثغرات الأمنية**
- قبل أن يستغلها:
  - هكر خبيث (Black Hat)
  - أو هجمات فدية
  - أو تسريب بيانات

يعني باختصار:

يضرب النظام "اختبار اختراق" قبل ما يضربه مهاجم حقيقي

❖ **ماذا يفعل عمليًا؟**

الهكر الأخلاقي لا "يخمّن"، بل يعمل بخطة ومنهجية، مثل:

◈ 1.الاستطلاع (Reconnaissance)

- جمع معلومات عن النظام:
  - نطاقات
  - سيرفرات
  - عناوين IP
  - تقنيات مستخدمة

◈ 2. فحص الثغرات (Vulnerability Assessment)

- البحث عن:
  - ثغرات برمجية
  - إعدادات خاطئة
  - كلمات مرور ضعيفة

◈ 3. الاختراق التجريبي (Penetration Testing)

- محاولة استغلال الثغرات **بشكل آمن**
- دون إتلاف البيانات أو تعطيل الخدمة

◈ 4. إعداد التقرير

- أخطر مرحلة 👈
- يكتب تقريرًا يشرح:
  - نوع الثغرة
  - درجة خطورتها
  - كيف يمكن استغلالها
  - **كيفية إصلاحها**

❖ ▲ علاقته بمثلث CIA

الهكر الأخلاقي يساهم مباشرة في حماية **مثلث** **CIA الذي شرحناها في الدرس الأول**

🔐 1. Confidentiality – السرية

- يمنع تسريب:
  - بيانات المستخدمين
  - كلمات المرور
  - المعلومات الحساسة

✅ 2. Integrity – السلامة

- يضمن عدم:
  - التلاعب بالبيانات
  - تعديلها بشكل غير مصرح

🚀 3. Availability – التوفر

- يحمي الأنظمة من:
  - هجمات حجب الخدمة (DDoS)
  - الأعطال الناتجة عن هجمات

🧑‍💻 ما المهارات المطلوبة؟

الهكر الأخلاقي عادة يكون قوي في:

- 🌐 الشبكات (Networking)
- 💻 أنظمة التشغيل (Linux / Windows)
- 🔐 التشفير
- 🐍 لغات البرمجة (Python – JavaScript – Bash)
- 🛠 أدوات الاختبار (Metasploit – Nmap – Burp Suite)

لكن الأهم من كل هذا:

الأخلاق والمسؤولية

🏆 لماذا الشركات تحتاجه؟

لأن:

- تكلفة توظيف White Hat ✅ >
- تكلفة اختراق حقيقي ❌

الاختراق قد يسبب:

- خسائر مالية
- تشويه السمعة
- قضايا قانونية

الهكر الخبيث – Black Hat

☠️ من هو؟

الهكر الخبيث هو **شخص يمتلك مهارات تقنية عالية** في مجال الاختراق، لكنه يستخدمها:

- ❌ **بدون إذن قانوني**
- ❌ **لأهداف غير مشروعة وغير أخلاقية**

لا يعمل على حماية الأنظمة أو تحسينها، بل يستغل الثغرات لتحقيق مكاسب شخصية أو لإحداث أضرار متعمدة.

🎯 أهداف الهكر الخبيث

تشمل أهدافه الرئيسية ما يلي:

📁 سرقة البيانات

- بيانات شخصية
- معلومات بنكية
- أسرار تجارية أو حكومية
  👉 غالبًا يتم بيعها في الأسواق السوداء.

🕵️ التجسس

- مراقبة المستخدمين أو الشركات
- سرقة معلومات حساسة
- اختراق الخصوصية

💣 تخريب الأنظمة

- تعطيل مواقع وخدمات
- تدمير قواعد بيانات
- إيقاف أنظمة حيوية عن العمل

💰 هجمات الفدية (Ransomware)

- تشفير البيانات
- مطالبة الضحية بمبلغ مالي مقابل فك التشفير
- تهديد بنشر البيانات في حال رفض الدفع

📉 النتائج المترتبة على هجمات Black Hat

❌ خسائر مالية ضخمة

- فقدان أموال مباشرة
- تكاليف استعادة الأنظمة
- تعويضات قانونية

❌ تدمير سمعة الشركات

- فقدان ثقة العملاء
- انسحاب شركاء
- صعوبة الاستمرار في السوق

❌ مساءلة قانونية وعقوبات جنائية

- السجن
- غرامات مالية كبيرة
- ملاحقة قانونية دولية في بعض الحالات

🚫 **لماذا يُعد الأخطر؟**

الهكر الخبيث:

- لا يراعي أي أخلاق أو قوانين
- يستهدف الأفراد والشركات والمؤسسات
- يضرب **السرية، السلامة، والتوفر** (مثلث CIA) في آنٍ واحد

⚠️ لذلك يُعتبر **أكبر تهديد في الفضاء الرقمي الحديث**

هكر القبعة الرمادية – Gray Hat

🕵️ **من هو؟**

هكر القبعة الرمادية هو شخص **يقف في المنطقة الوسطى** بين:

- الهكر الأخلاقي (White Hat) ⚪
- والهكر الخبيث (Black Hat) ⚫

يمتلك مهارات اختراق حقيقية،
لكن **التناقض الأساسي** عنده هو:

يخترق الأنظمة **بدون إذن**، رغم أن نواياه ليست تخريبية غالبًا.

⚖️ **طبيعة سلوكه**

سلوك الـ Gray Hat يتميز بالتالي:

- 🔓 يقوم بالاختراق دون موافقة رسمية
- 🧠 لا تكون نيته سرقة أو تخريب
- 🚫 لكنه أيضًا لا يلتزم بالإطار القانوني

يعني باختصار:

نية بيضاء + تصرف أسود = منطقة رمادية

🎯 **دوافع هكر القبعة الرمادية**

أشهر الدوافع تشمل:

🧪 **إثبات المهارة**

- يريد إظهار قدرته التقنية
- بناء سمعة داخل مجتمع الأمن السيبراني

📢 **إبلاغ الشركة بالثغرة**

- بعد الاختراق، يتواصل مع الشركة

- قد يطلب منهم إصلاح الثغرة

💰 **طلب مكافأة Bug Bounty بدون اتفاق مسبق**

- يكتشف ثغرة
- ثم يطلب مكافأة رغم أنه:
  - لم يكن ضمن برنامج رسمي
  - ولم يحصل على إذن مسبق

وهنا تبدأ المشكلة القانونية 👇

🚨 **لماذا يُعد سلوكه خطيرًا؟**

رغم أن نية Gray Hat قد تكون "جيدة"، إلا أن شركات كثيرة تعتبره:

- ✅ اختراقًا
- ✅ انتهاكًا للسياسات
- ✅ خطرًا أمنيًا محتملاً

لأن:

- الاختراق تم دون علمهم
- لا يمكن ضمان أنه لم ينسخ بيانات
- لا يوجد تحكم قانوني في ت

⚠️ **نقطة قانونية مهمة جدًا**

🔴 **القانون لا يعترف بالنيات... بل بالإذن**

- لا يهم أنك:
  - أردت المساعدة
  - أو لم تُسبب ضررًا
- المهم:
  - هل لديك إذن مكتوب؟ ✅ أو ❌

في أغلب الدول:

- تصرف Gray Hat يُصنَّف **غير قانوني**
- وقد يعرّضه لمساءلة قانونية

جدول مقارنة بين أنواع الهكر (White – Gray – Black Hat)

أي محاولة اختراق أو فحص أنظمة بدون إذن رسمي ومكتوب تُعد مخالفة قانونية،
بغض النظر عن النية أو عدم حدوث ضرر.

🔴 **القانون لا يحاسب على النيات، بل على الأفعال والإذن.**

أي محاولة اختراق أو فحص أنظمة **بدون إذن رسمي ومكتوب** تُعد مخالفة قانونية،
بغض النظر عن النية أو عدم حدوث ضرر.

🔴 القانون لا يحاسب على النيات، بل على الأفعال والإذن.

تنويه

أي محاولة اختراق أو فحص أنظمة **بدون إذن رسمي ومكتوب** تُعد مخالفة قانونية،
بغض النظر عن النية أو عدم حدوث ضرر.

- القانون لا يحاسب على النيات، بل على الأفعال والإذن.